

Zerava – Pre-Development Planning (Before Any Code)

This document defines everything that must be decided, agreed on, and documented **before** writing a single line of frontend or backend code. If this is skipped, execution will be slower, messier, and full of avoidable arguments.

1. Product Clarity (Non-Negotiable)

1.1 Core Goal

Zerava's goal is to provide **fast, high-signal security insights** for startups and small teams.

Not goals: - Not full penetration testing - Not enterprise SIEM replacement - Not hacker-focused tooling

The product must deliver value **in under 60 seconds**.

1.2 MVP Definition

The MVP must answer one question clearly: > "Is my public-facing system dangerously insecure right now?"

MVP includes: - URL or API input - Automated scan - Security score (0-100) - Limited, high-impact findings - Clear, founder-friendly explanations

Anything outside this is postponed.

2. Scope Lock (What We Are NOT Building)

Before coding, explicitly agree to exclude: - Authentication complexity (SSO, RBAC, teams) - Advanced compliance automation - Deep cloud security (IAM, VPC, etc.) - Internal network scanning - AI hype features without clear value

Scope creep kills MVPs. This list exists to stop it.

3. Target User Definition

Primary user: - Early-stage founder - Small technical team - Limited security knowledge or time

User expectations: - Clear language - Low noise - Actionable fixes - Trustworthy results

Every decision must serve this user, not security ego.

4. Frontend-Backend Contract (Critical)

4.1 Responsibility Split

Frontend (React): - UI/UX - User input handling - Scan progress visualization - Result presentation

Backend (Flask): - Scan execution - Risk analysis - Scoring logic - Explanation generation

No overlap. No guessing.

4.2 API Contract Definition

Before coding, define: - Request formats - Response schemas - Error formats - Scan state lifecycle (queued, running, completed, failed)

This must be written and agreed on before implementation.

5. Scanning Philosophy

5.1 Signal Over Coverage

Zerava prioritizes: - High-confidence findings - Business-impact relevance - Low false positives

Initial scan checks should be limited and deliberate.

5.2 Explainability Rule

Every finding must include: - What the issue is - Why it matters to the business - Exactly how to fix it

If it cannot be explained simply, it does not belong in the MVP.

6. Security Score Design

Before coding, define: - How scores are calculated - How much weight each severity has - How score changes are explained

Rules: - Score must be stable - Score must be explainable - Small changes should not cause extreme swings

The score is a trust mechanism, not a gimmick.

7. Architecture Decisions (High Level)

Decide upfront: - API-only backend - Asynchronous scanning model - Job-based scan execution - Stateless frontend

Avoid framework debates once execution begins.

8. Data Model (Conceptual, Not Code)

Define conceptually: - Scan object - Finding object - Score object - Report object

No database schema yet. Just shared understanding.

9. Success Criteria for MVP

The MVP is successful if: - A user can run a scan without guidance - Results are understandable without security knowledge - Findings feel relevant and trustworthy - The product works consistently

Anything beyond this is iteration, not MVP.

10. Execution Rule

Only after all sections above are: - Written - Agreed on - Locked

Do we begin implementation.

Execution without clarity is wasted effort.

This document is the contract. Code comes after.